Final report DEDSEC

Grenoble INP - Esisar

PX505 - Innovation Project

DEDSEC :

Demonstrating Effective Defense and Security Exploitation for Connected devices

---

NGUYEN VAN BINH Julien
ATTIA Sara
WASSEM Muhammed

Table of content

1. Abstract....2

2. Introduction....3

3. Related work....4

4. Demonstrator Architecture....6

5. Validation environment and results....9

6. Societal challenge.... 16

7. Conclusion.... 17

8. References....17

9. Annex....18

1. Abstract

The use of IOT devices is a double edged sword that can be immensely useful and dangerously harmful due to its access to sensitive data of. The call for security has been tempting.

The aim of this project is to raise awareness about the effects of cyberattacks. We selected a scenario that utilizes iot powers, and figured out some vulnerabilities. In light of ethical hacking, we exploited those vulnerabilities to attack two devices which are Smart Plugs and 6TRON sensor in a scenario of having a smart irrigation system that can be in a home garden. we managed to break the remote control of the smart plug and crack the home network credentials and manipulate the sensor data.

We give some advice on countermeasures to avoid those types of attacks to both industrial products and people to secure their lives.

2. Introduction

With the rise of connected devices in our daily lives, such as smart TVs, connected printers, and wearable gadgets, or other Internet of Things (IoT) devices, the issue of data security, cybersecurity and protection against cyberattacks has become increasingly critical. While these devices provide comfort and improve lives of the users, they often have security vulnerabilities that users are not always aware of, where some “attackers” or “hackers” can take advantage of.

The goal of this project is to identify these vulnerabilities in connected devices, analyze the associated risks, and develop an interactive educational tool that clearly demonstrates these vulnerabilities and their solutions. We aim to raise awareness about cybersecurity threats not only for technical people but also for non-technical people in their daily lives. IOT devices have access to sensitive data in our daily lives. IOT devices could be safety cameras, door locks, a baby phone, Alexa, smart kettle, smart fridge, thermostat and so much more.

We selected a scenario of so many scenarios that utilize IOT in our homes which includes some smart features in an irrigation system that could be in a home garden. We identify the vulnerabilities of this system, analyze the feasibility of some vulnerabilities and demonstrate the attack that caused damage. We suppose that there’s a water pump connected to a smart plug that could be controlled remotely either turning the pump on or off. There’s also a device to sense some data like temperature and humidity. That data could be accessed remotely in order to make some decisions for the garden.

We identify some vulnerabilities in the smart plug. Being around this wifi range, we managed to disconnect the smart plug from the internet which stops the remote control of this device. The device stands still on its previous status which can be the water pump on or off. Being around this wifi range, we could sniff the communication and using some tools we could crack the password of the home network which means, we could sneak into the home network. This process requires us to be around the range of the network for only one time during the pairing process so the feasibility of the attack is quite high. The threat of being inside the network opens the door for much more threats. The other hack is for The 6TRON sensor, in which we could sniff the data and read it using the Man In The Middle attack (MITM) concepts, we could also manipulate the data and send mistaken data which can cause wrong decisions at the end. The communication used in the 6tron sensor is bluetooth low energy.

At the end, we could showcase some critical consequences of our attack using simple devices with vulnerabilities. Through the report, we will showcase the potential of iot hacking on our daily lives and the serious outcomes of it.

3. Related work

IOT devices are widely used because of the comfortness, automation and time saved that it provides. The functionality of those iot devices depend heavily on data collection, communication and connection between different devices and different metrics. Those points of strength are the same backdoor that can make any attacker get to hack. IOT devices have common vulnerabilities that should be secured and taken into consideration in the journey of making any industrial iot device.

According to article **[1]**, Together, NETGEAR and Bitdefender, a leading provider of cybersecurity software worldwide, were examining the security threats that modern smart homes face as well as what lies ahead. They examined threat data from the 3.8 million homes worldwide that are and looked into roughly 50 million IoT devices that produce over 9.1 billion security events. The statistics show that: Every 24 hours, home network devices see an average of 10 attacks. Every 24 hours, Bitdefender security solutions block an average of 2.5 million threats, or roughly 1,736 threats per minute. Fortune Business Insights projects that by 2030, the U.S. IoT market will have grown by 24.7% from $118.24 billion in 2023 to $553.92 billion. This affects the homes as well as business, but it also represents amazing new opportunities. These days, the average home has 21 devices linked to the home network. These items are made to improve comfort, convenience, security, and energy efficiency.

Check Point Research found a sharp increase in cyberattacks targeting IoT devices, observing a trend across all regions and sectors. Europe experiences the highest number of incidents per week: on average, nearly 70 IoT attacks per organization.**[2]**

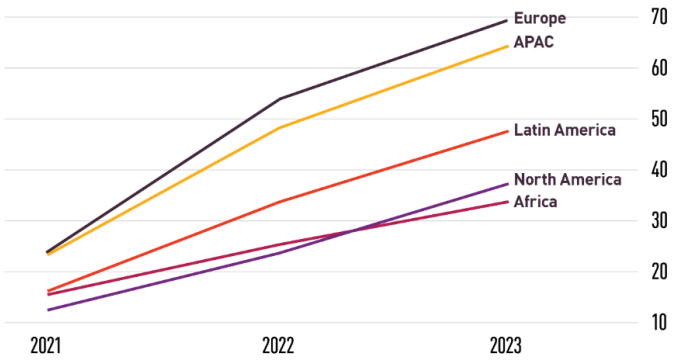


Fig 1.The average number of IoT attacks per organization, broken down by region on a weekly basis.

The Open Web Application Security Project (OWASP) is an online community that produces freely available articles, methodologies, documentation, and technologies in the fields of IoT, IoT security and other things. It is led by a non-profit called The OWASP Foundation. The challenges they present are because

of lack of security in web interfaces, lost authentication, and authorization risks. OWASP IoT project is among their top 10 projects and it's focused on risks identification, helping to provide manufacturers, developers and normal users with the important knowledge of how to protect against those risks. According to The OWASP **[3]**, those are the top IoT risks:

1. **Weak, guessable, or hard-coded passwords:** IoT devices tend to have web-based interfaces or mobile applications to allow use of the device, perform configurations, manage network services and authenticate tasks in the device. When those configurations are not done securely, attackers could access sensitive information. Security testing has proven that the majority of IoT devices have the issue of guessable, weak, or fixed passwords and usernames. This paves the road for an attacker to get through sensitive data.
   Recommended Solutions:
   - To ensure that passwords are safe, manufacturers should implement suitable authentication and password management systems.
   - When performing device setups, users should be urged to use strong, one-of-a-kind, and challenging-to-guess passwords.
2. **Insecure Network Services:** weak insecure network protocols (like: FTP, WPA/WPA2), lack of proper network security configurations and using old firmware form a way for attackers to exploit.
   Recommended Solutions:
   - Always using the latest most secure network protocols and regularly updating firmwares and security configurations. That depends on both the user and the manufacturer that should both adopt the security urge.
   - implementing periodic network vulnerability assessments help will help detect risks early
3. **Insecure ecosystem interfaces:** it allows hackers to access private information or take control of devices through insecure web, API, or mobile interfaces. User information such as location, passwords, and connected devices may be made public by unauthorized APIs. These problems are a result of inadequate authorization in IoT security.
   Recommended solutions: Consistent patching of APIs, implementing stringent access controls to limit access to sensitive interfaces and APIs.
4. **Lack of secure update mechanism:** outdated softwares can allow attackers to compromise the overall device security.
   Recommended solutions: Implementing features like digital signatures, secure delivery, anti-rollback mechanisms, and firmware validation on devices.
5. **Using insecure or outdated components:** third-party or open-source components can be vulnerable.
6. **Insecure data transfer and storage:** This can be data collection without the user's consent, data storage without adequate security controls, and data sharing with third parties without appropriate permissions.
   Recommended solutions: using privacy-by-design principles,

including encryption and gaining user consent for data collection and avoiding plaintext data transfer like HTTP protocol for sensitive data.

7. **Absence of device management:** An example is the expired SSL certificates that can cause communication to be over HTTP.

4. Demonstrator Architecture

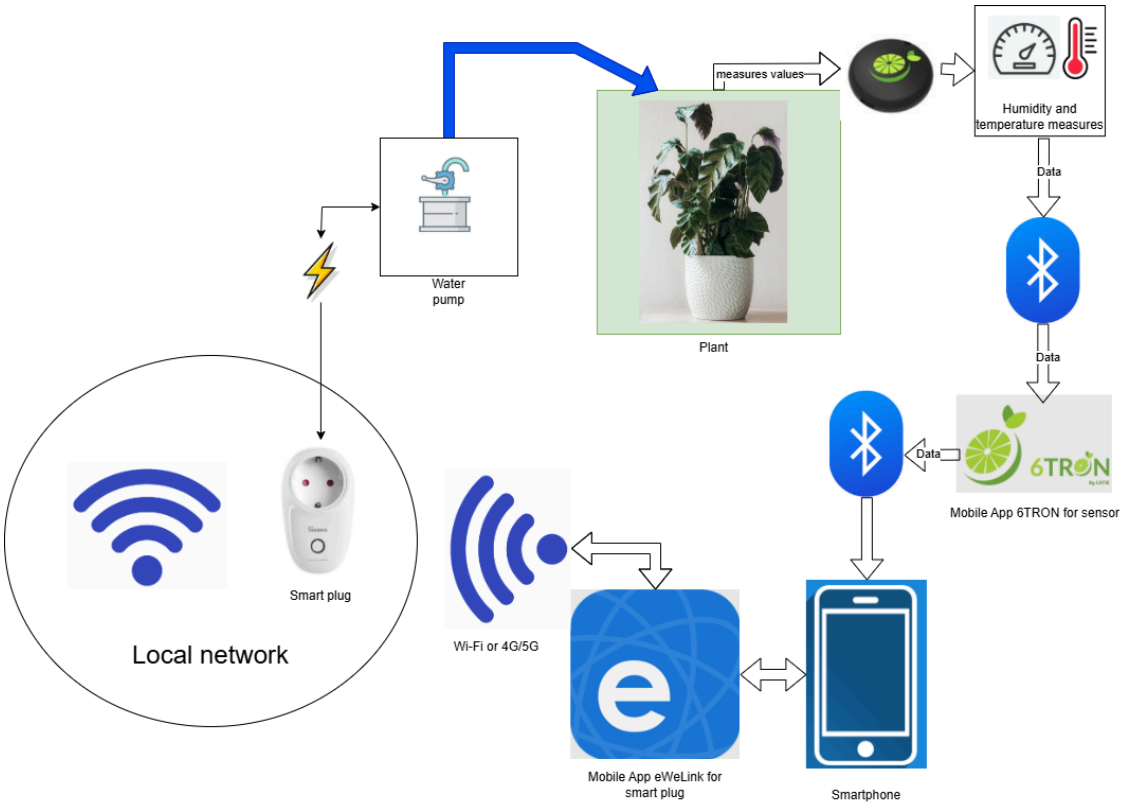


Fig 2: Demonstrator architecture

The purpose of this architecture is to simulate a real-world IoT setup and demonstrate the vulnerabilities and potential attacks on devices such as a smart plug and a BLE sensor within a smart irrigation system.

The objective is to show the use case of an irrigation system, then to execute attacks to disrupt the functionality of the devices, the objective is to educate users on the risks and consequences of IoT vulnerabilities.

<u>Component of the system :</u>

- ➔ A non-connected water pump that waters a plant
- ➔ A smartphone with the needed applications
- ➔ Smart plug (Sonoff S26) : Provides remote on/off control for the water pump using smartphone over Wi-Fi.

- ➔ BLE Sensor (6tron) : A sensor that measures temperature and humidity, it sends environmentals data to a smartphone via BLE with the 6tron application
- ➔ A Wi-Fi router or a hotspot, to connect the smart plug to a local network.

Use case

A smart irrigation system is designed, for a home garden for example, this system has IoT devices such as the smart plug and the BLE-sensor, to manage the garden, and to automate it in some cases. The smart plug controls a non-connected water pump, allowing the user to remotely turn it on or off via the smartphone application, simultaneously, the BLE sensor measures the environmental condition like temperature and humidity, transmitting real-time data to a mobile app, the user can make action (watering plants), depending of the measure, and with these measures, he can automate it if he wants.

This setup provides the user optimal conditions for plant growth.

Protocols and vulnerabilities

- ➔ Wi-Fi (WPA/WPA 2): Used by the smart plug for communication, vulnerable to deauthentication attacks due to the lack of protected management frames.
- ➔ Bluetooth Low Energy (BLE) : Used by the sensor to transmit data, vulnerable to MITM attacks due to weak encryption and lack of mutual authentication

During the attack

The next step is to demonstrate how this architecture can be vulnerable.

Smart plug attack

A Wi-Fi deauthentication attack is launched against the smart plug, forcing it to disconnect from the local network with aircrack-ng tool (See annex)

The consequences are immediate, the remote control of the smart plug (and therefore, of the water pump) is completely disabled.

BLE sensor Attack

A BLE attack Man-In-The-Middle (See annex) is conducted, intercepting and manipulating the data between the sensor and the smartphone.

The attacker sends falsified data to trick the user, based on these falsified readings, the user or automated systems make incorrect decisions.

The combined impact of these attacks disrupt the normal operation of the irrigation system.

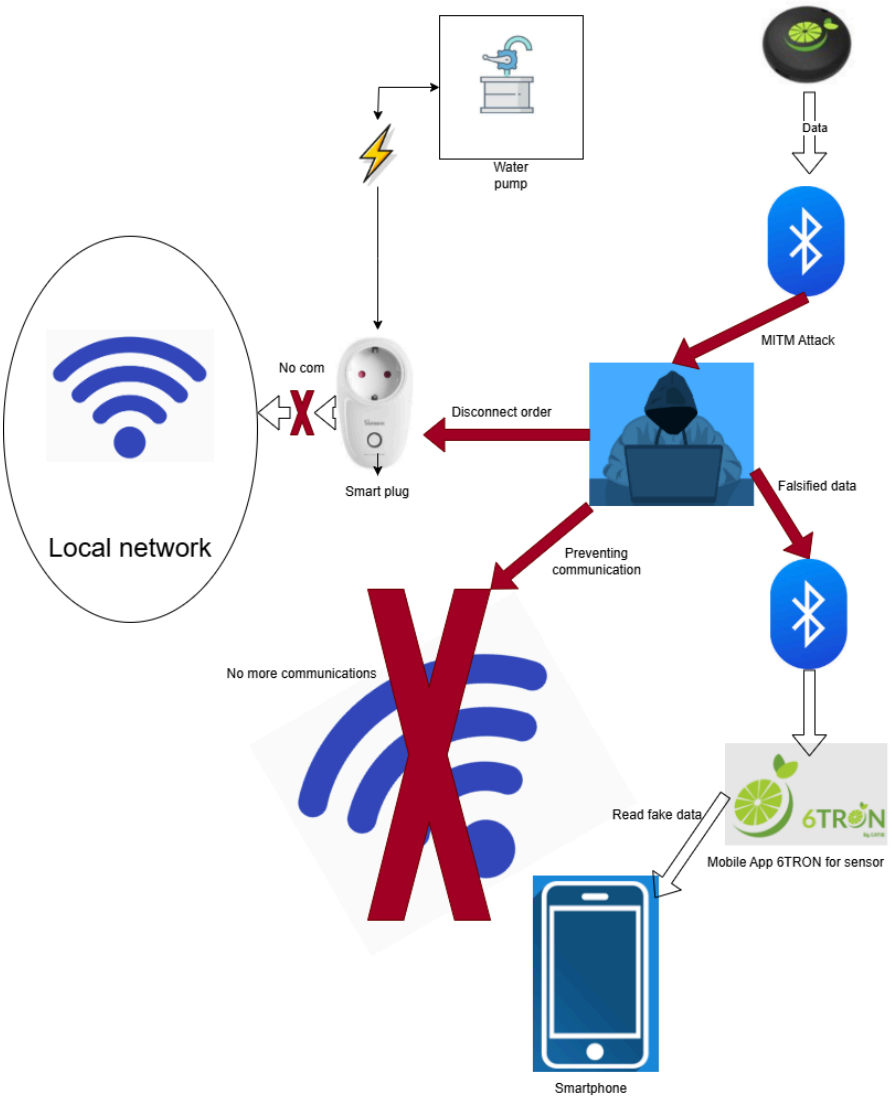


Fig 3. Attack the architecture

This attack phase demonstrates how the vulnerabilities identified in the IoT system can be exploited to disrupt its functionality and compromise it.

Using only a Linux computer with appropriate software tools, a Wi-Fi antenna and BLE dongle, the entire system can be compromised.

5. Validation environment and results

This section will describe the validation environment established to test our demonstrator, as well as the results obtained. The main objective of this part is to evaluate the effectiveness, the relevance and the good functioning of our demonstrator, in real conditions, this validation aims to confirm the reliability and practicality of our approach in identifying vulnerabilities.

Validation and scenario of Wi-Fi attack

For the Wi-Fi attack we used the equipments :

- Smart plug : Sonoff S26, connected to the local Wi-Fi
- Linux computer with Wi-Fi Antenna : Operating in monitor mode for packet sniffing and injection
- Smartphone : with the “eweLink” app.
- Wireshark : tool to capture network traffic

Context of the scenario:

The smart plug operates under the WPA/WPA2 protocol and is controlled via a smartphone with the “eweLink” application, this allows the user to control by distance the smart plug and so, to control the device (IoT or not) by distance, but in this scenario, we will show how a “simple” deauthentication attack can exploit vulnerabilities in the WPA protocol to disable this functionality.

In our selected scenario, we will use the smart plug to control a non-connected water pump, which can be used for tasks like watering plants and the smart plug enables remote on/off control of the pump via the smartphone application, even when the user is away from home, once the pump is plugged to the smart plug, it operates as soon as the plug is powered on.

In this context, a “deauthentication attack” targets the smart plug to disable its connection from the local Wi-Fi network, this attack will prevent the user from controlling the plug with his smartphone, leaving it in its last known state (on or off). If the user is too far to intervene manually, this loss of control could result in unwanted consequences, such as overwatering the plants or failing to water them as needed.

Attack execution and objectives:

Prepare the attack

To prepare this attack, we plug in our smart plug and integrate it into a local network using our smartphone via the “eWelink” application, once the smart plug is connected, we set up our Linux PC (with the necessary packages and tool) and connect our Wi-fi Antenna (More details in the annex), from there, we have the typical scenario and the attack is ready to begin.

Step 1 : Analyze the network

Before launching the deauthentication attack, we must first analyze the network to identify the target smart plug. Without prior knowledge of the network, we use sniffing tools and Wireshark to capture information about connected devices, particularly the smart plug (See annex).

Setting the Wi-Fi Antenna to Monitor Mode (Details in annex)

We (the attacker) use a compatible Wi-Fi antenna to enable the monitor mode, in this mode, the antenna listens to all network traffic within range without needing to connect to a specific network, this allows us (the attacker) to capture all wireless communications, including those transmitted by the smart plug (and other devices connected to the local Wi-Fi network).

To capture the traffic, we use Wireshark, a packet-capturing tool, to inspect the network traffic, by capturing packets, it provides insights into the communications exchanged by devices, this can include :

- ➔ SSID (Service Set Identifier) : Name of Wi-fI network, particularly the one we need (the one which the smart plug is connected)
- ➔ MAC Addresses : The unique MAC address of the smart plug and other devices
- ➔ Protocol used

After capturing the packets, the focus is on packets like “handshake”,”probe request” or “broadcast” or packet which contains an SSID frame so we can identify the Wi-Fi Access Point, and it can be used with a different filter with Wireshark. The main goal is to obtain the MAC Addresses of the smart plug and the Wi-Fi router, and to obtain the network’s security details (here WPA/WPA2)

Step 2 : Launch the attack

After identifying the target smart plug and its associated network with the MAC Addresses, the attacker can proceed to execute the deauthentication attack, it will force the smart plug to disconnect from the Wi-Fi network, leaving it in its last state, and preventing the user from intervening remotely.

To launch the attack, packets of force deauthentication are sent with the “aireplay-ng” tool (More info in annex), these packets are designed to trick both the smart plug and the Wi-Fi router into believing that the other has requested disconnection. One command from this tool is enough to launch this attack.

Step 3 : Observation

Once the deauthentication packets are sent, the impact are :

- ➔ The smart plug is disconnected from the Wi-Fi network, so the user can no longer control the plug remotely

➔ The last known state of the smart-plug is operating, so it can cause trouble if the user wanted to power off the plug (or vice-versa)

If the smart plug attempts to reconnect to the network, the attacker can maintain the deauthentication attack by continuously sending packets, this ensures that the device remains disconnected for as long as the attack is active.

By completing all these steps, the attacker successfully disrupts the smart plug's connection.

Results,impact, feasibility, discussion and countermeasures:

After successfully executing the deauthentication attack, the attack results in a "Device state persistence" which means the smart plug remains in its last known operational state, the inability to control the smart plug remotely could lead to undesirable outcomes such as overwatering or underwatering plants and therefore, loss of trust in the reliability of IoT devices for tasks. In small-scale scenarios like this one, the consequences are limited to personal inconvenience and potential damage, but at larger scales, the attack could lead to financial losses or compromise security depending on the device which is plugged to the smart plug.

This attack demonstrates how IoT devices relying on unsecured Wi-Fi protocols are vulnerable to simple and effective attacks. The attacks require relatively simple and affordable equipment, no advanced expertise is needed, and step-by-step guidance makes the attack possible for everyone.

Physical proximity to the target network is necessary to execute this attack, an effective countermeasure such as WPA3 or advanced router configurations, could reduce the attack's success rate.

This scenario highlights a fundamental issue in IoT device security : the reliance on insecure communication protocols and the lack of robust authentication mechanisms, it shows, on some devices like the smart plug, that convenience and cost are often prioritized over security.

Validation and scenario of BLE attack

For the BLE attack we used the equipments :

- 6tron sensor
- Linux computer
- 2 BLE dongles for the MITM attack
- Smartphone : with 6tron application

Context of the scenario:

A humidity and temperature sensor is used on the same plant, the sensor operates via Bluetooth Low Energy (BLE) and communicates its measurements to a smartphone through a mobile app, the user relies on this data to monitor and adjust the plant watering system to ensure optimal conditions for the plants.

The sensor continuously measures environmental data and transmits it to the smartphone in real time, this information helps the user decide when and how much water the plants need.

An attacker can exploit the BLE protocol to compromise the system's functionality by doing a "Man-In-The-Middle" (MITM) attack.

Attack execution and objectives:

Prepare the attack

Before executing the attack, necessary tools must be set-up, this involves a Linux computer with two BLE dongles.

Step 1 : BLE Scanning

A BLE scan is performed to identify nearby devices, using tools such as Hcitool**[4]**,Mirage**[5]**or Whad**[6]**on linux, the attack collects information about the devices broadcasting BLE signals. The objective of this scan is to identify the MAC address and characteristics of the target sensor

The procedure is simply to enable the scanning with one BLE dongle and to see the results in order to capture the MAC address of the target sensor.

Step 2 : Launch the attack

After identifying the target sensor, the attacker proceeds to impersonate it by cloning its BLE characteristic and creating a fake device that mimics its behavior.

The objective is to trick the smartphone into connecting to the attacker's device instead of the legitimate sensor, enabling the attacker to manipulate the data sent to the smartphone.

The procedure to execute the BLE Man-in-the-Middle (MITM) attack needs two BLE dongles. The goal is to intercept and manipulate the communication between the BLE sensor and the user's smartphone, using the first BLE dongle, the attacker establishes a connection with the target device (the BLE sensor), with the second BLE dongle, the attacker broadcasts a signal that mimics the BLE sensor, cloning the device. The cloning phase is a simple procedure made by Linux BLE tools like Mirage or Whad (See Annex and reference).

All data sent by the sensor is first intercepted by the attacker and then relayed to the smartphone, so the attacker can modify theses data.

Step 3 : Observation

Data are manipulated and falsified, and are sent to mislead the user, altered humidity and temperature readings can be sent to the smartphone application (e.g

consistently high or low) so the user's decision or the automated system's behavior is affected

This structured execution highlights of BLE vulnerabilities such as unencrypted communications or weak authentication can be exploited to compromise the integrity of IoT systems.

Results,impact,feasibility, discussion and countermeasures:

The BLE MITM attack demonstrated the following outcomes:

- ➔ The attacker successfully cloned the target sensor's BLE characteristics and created a fake device
- ➔ The smartphone connected to the attacker"s fake device, believing it was the legitimate sensor

Falsified data readings were sent to the smartphone application to indicate abnormally high or low values of measures, this can lead to incorrect decision

The attack requires relatively simple tools such as BLE dongles and Linux-OS PC, no physical access to the sensor is needed, just a proximity within BLE range is sufficient. Step-by-Step instructions and open-source tools for BLE scanning and MITM/Spoofing are available, making this type of attack really feasible by everyone.

BLE communication often lacks encryption or robust authentication, leaving the devices vulnerable, this experiment highlights the need to counter these attacks to ensure data integrity.

To counter this attack, devices can have a mutual authentication (double authenticator) to prevent the MITM, or encrypting the transmitted data would make it difficult for attackers to intercept.

This can lead to the same risks as the Wi-Fi vulnerability mentioned above at a larger scale.

Performance criteria

Our educational tool must demonstrate IoT vulnerabilities in a clear,practical and reproducible manner, that's why we have to highlight the important key :

- ➔ Simplicity and accessibility : The tool uses available hardware and open-source software, ensuring accessibility to a wide audience ,even with minimal technical expertise, the setup and the execution is easily understandable
- ➔ Reproducibility : The scenario is designed to be reproducible in various IoT environments, in order to extend the vulnerabilities to many uses cases
- ➔ Clarity : The tool provides a Step-By-Step visualisation of the different attacks, it ensures that the audience can clearly identify the impact.

These criterias are really important in the development of our tool.

Challenges faced

The development of our educational tool presented several challenges that made harder the implementation of the real-world IoT attacks while maintaining accessibility and feasibility. One of the first difficulties was the selection of an appropriate IoT device to demonstrate. The chosen device had to be widely accessible and affordable, while also presenting a relevant vulnerability that was both impactful and feasible to exploit. This balance was particularly difficult to achieve, as not all IoT devices meet these criteria, especially when the primary goal is to create a practical and educational demonstrator.

Moving from theory to practice revealed additional difficulties. While the theoretical steps for the attacks were well-documented and appeared "straightforward", implementing them was far more complex.

For the smart plug, the initial goal was to capture Wi-Fi credentials in plaintext packets. However, it became clear during testing that these credentials were encrypted and could not be directly retrieved from captured traffic. This forced us to change our approach and instead focus on executing a deauthentication attack which was a better idea. Revising this strategy required additional research and consumed valuable time, adding more difficulty between theoretical feasibility and practical execution.

The BLE attack on the 6TRON sensor posed even greater technical challenges. Tools such as Whad and Mirage, which were critical for the MITM attack, often failed to function as expected on the first attempt. We encountered numerous issues, including outdated software, driver incompatibilities, missing devices, and hardware limitations. Each of these problems had to be resolved individually, requiring various troubleshooting and significant time investment. In some cases, despite following the available documentation, the attacks did not perform as described, leaving many unanswered questions even after extended research and testing.

Finally, a recurring challenge was dealing with uncertainties and logistical constraints. Missing hardware, compatibility issues, and tool updates frequently disrupted progress. Even after resolving many of these issues, some questions remained unresolved, highlighting the unpredictability of working with real-world vulnerabilities and tools. These challenges changed the nature of the process and the effort required to adapt and review methods in the face of unexpected obstacles.

Other possibles attacks and scenarios due to the vulnerabilities

While the water plant scenario represents a straightforward use case, similar vulnerabilities in BLE or Wi-Fi connected devices can lead to much greater consequences when applied in larger-scale or critical systems.

A camera connected to the smart plug can be critical and with the same deauthentication attacks, the camera can be disabled, preventing the user from seeing what is happening in front of the camera.

In an industrial setting, a smart plug could control automated machinery or critical systems, like a conveyor belt. Losing control over the device could result in prolonged downtime, damage to machinery or even safety hazards for personnel.

Medical devices data can be manipulated with the BLE attacks like insulin pumps or glucose monitors, the patient might administer the wrong dosage because of the falsified data.

A BLE-enabled smart lock can be vulnerable to this attack too, the attacker can intercept the communication and can capture the command to unlock the door to gain unauthorized access.

General results

The results obtained from the validation environment and attack scenarios confirm the effectiveness of the demonstrator in identifying and exploiting IoT vulnerabilities. With simple tools, such as a Linux computer (and his integrated tools), a Wi-Fi antenna, and BLE dongles, the attacks demonstrated the important vulnerabilities of IoT. Both attacks were executed with easily accessible tools and well-documented methods, showing how “easy” it is to compromise IoT systems.

Users may lose confidence in IoT devices if such vulnerabilities are exploited widely, affecting the adoption of smart technologies.

IoT systems must implement stronger security measures like mentioned above because the risks around theses unsecured IoT devices is real

While all these attacks were operating within the scope of our educational tool, there is nothing preventing such vulnerabilities from being exploited across many other domains. The scenarios we demonstrated in a smart irrigation system can easily extend to other IoT applications, such as home security, healthcare devices, industrial automation, and more.

Other vulnerabilities

However, these vulnerabilities represent only a fraction of the potential risks that exist in many connected systems.

For example, by capturing network packets with tools like Wireshark, an attacker can easily extract information such as the SSID and MAC addresses of devices. This information makes possible the “device spoofing”(See annex), where an attacker impersonates a legitimate device on the network.

Another significant vulnerability involves the handshake process that occurs when a smart plug reconnects to the network after a deauthentication attack. During this process, handshake packets are exchanged between the smart plug and the router, containing encrypted Wi-Fi credentials. An attacker can capture these packets and, using tools like Aircrack-ng, perform a brute-force attack to crack the Wi-Fi credentials. Once access to the network is obtained, the attacker can exploit other connected devices, access sensitive data, or cause additional disruptions (More details in annex).

6. Societal challenge

The increasing integration of IoT (Internet of Things) devices into everyday life presents both opportunities and risks for society. While these devices offer comfort and innovation, they also introduce significant vulnerabilities that can threaten privacy, security, and even public safety. Our project goal is to make people aware of these issues by highlighting some of the security risks associated with IoT technologies, thereby raising awareness and promoting responsible development and usage of these devices.

1.Privacy and data security

One of the primary societal concerns surrounding IoT devices is the threat to personal privacy. IoT devices often collect vast amounts of data about users, including their location, habits, and personal preferences, or password (network password), when these devices are vulnerable to hacking, this sensitive information can fall into the wrong hands of attackers and hackers, leading to forms of exploitation and attacks, our project seeks to demonstrate how seemingly harmless devices, such as smart plug or smart light, or home assistants, can be used to steal your data.

2.Critical infrastructure risks

IoT devices are not limited to personal and domestic use; they are also becoming increasingly prevalent in critical infrastructure, such as healthcare systems and transportation networks. A successful attack on these devices could have very bad consequences, such as disrupting essential services or compromising public safety. By educating people about the vulnerabilities present in IoT devices, we can make them aware of the high consequences of bad security and bad management of IoT devices.

3. Awareness and education

Like it was mentioned just above, awareness is important because the key societal challenge with IoT technology is the lack of awareness about its potential risks. Many consumers are unaware of the security weaknesses in the devices they use every day, which leads to low security practices such as weak passwords or failure to update device software. By creating an educational tool, our project helps bridge this knowledge gap, empowering individuals and organizations to make informed decisions about the IoT devices they use, and to adopt better security practices.

The project is an innovative project, it offers a simple and accessible educational tool that clearly explains the risks associated with IoT devices to non-experts and non qualified people. Unlike existing resources, this tool will be understandable by the general public, even those without technical knowledge, aiming to spark their curiosity and raise awareness about cybersecurity issues. We play a role in limiting the societal risks associated with these technologies. By raising awareness, educating users, and highlighting the importance of securing IoT devices,

we aim to contribute to a safer, more secure technological landscape for individuals, businesses, and public infrastructure.

7. Conclusion

IoT devices in our daily lives have brought good convenience and innovation, transforming homes and industries. However, this dependence on connected devices also introduces significant security challenges, as demonstrated by our project. By exploring the vulnerabilities of two IoT devices—the smart plug Sonoff S26 and the 6TRON sensor—in a smart irrigation system scenario, we highlighted how attackers can exploit weaknesses of these devices to disrupt functionality, compromise sensitive data, and manipulate device behavior. Our work illustrates how relatively simple techniques, such as Wi-Fi deauthentication, network sniffing, and Bluetooth Low Energy (BLE) Man-in-the-Middle (MITM) attacks, can lead to severe consequences, such as disabling remote control features, accessing private networks, and sending falsified data. These attacks not only affect the integrity of IoT systems but also create potential threats to user privacy and safety.

Through this project, we aimed to raise awareness about the critical need for IoT cybersecurity. The vulnerabilities we identified and exploited reinforce the need of designing secure devices and educating users about potential risks. The development of our interactive educational tool is a step toward making cybersecurity knowledge accessible to both technical and non-technical audiences, empowering individuals to better protect themselves against cyberattacks.

In conclusion, while IoT devices offer many possibilities, their adoption must be accompanied by robust security practices. Both manufacturers and users play an important role in mitigating risks, whether through the development of secure products, regular firmware updates, or the implementation of strong authentication protocols. By taking proactive measures, we can employ the benefits of IoT while minimizing its potential dangers.

8. References

[1]https://www.netgear.com/hub/network/2024-iot-threat-report/#:~:text=Here's%20a%20shocking%20look%20at,roughly%201%2C736%20threats%20per%20minute.
[2]https://www.weforum.org/stories/2024/05/internet-of-things-dark-web-strategy-supply-value-chain/
[3] https://www.wattlecorp.com/owasp-iot-top-10/
[4] https://linux.die.net/man/1/hcitool
[5]https://hal.science/hal-02268774/file/SSTIC2019-Article-mirage_un_framework_offensif_pour_laudit_du_bluetooth_low_energy-alata_auriol_roux_cayre_nicomette.pdf
[6] https://whad.io/

9. Annex

This last part of the report is an annex, it serves as a complementary section to provide detailed technical insights and clarifications about the attacks and methodologies discussed in the final report. It is designed to offer a deeper understanding of the tools, procedures, and configurations used during the demonstrations.

This annex also includes tests, reports,command line and additional information about aspects of the project that were not fully explored, did not yield successful results, or were simply not mentioned in the main report. These elements provide a comprehensive view of the work made, including challenges faced and areas that remain “unfinished”.

Wireshark capture

In the context of Wi-Fi vulnerabilities, the initial step often involves capturing data packets to capture crucial network information. This is achieved using tools like Wireshark, which enables the identification of key details such as:

- ➔ MAC Address : Unique identifiers of devices
- ➔ IP Address : Identifier of a device within the network
- ➔ SSID : Name of Wi-Fi network or device
- ➔ Handshake packets : Critical packet that can be encrypted

Wireshark operates by analyzing the raw traffic captured by a Wi-Fi antenna configured in monitor mode. Using specific filters, attackers can isolate relevant packets, making it easier to target specific devices or networks. This step is essential in understanding the structure and vulnerabilities of the network before proceeding to any attack.

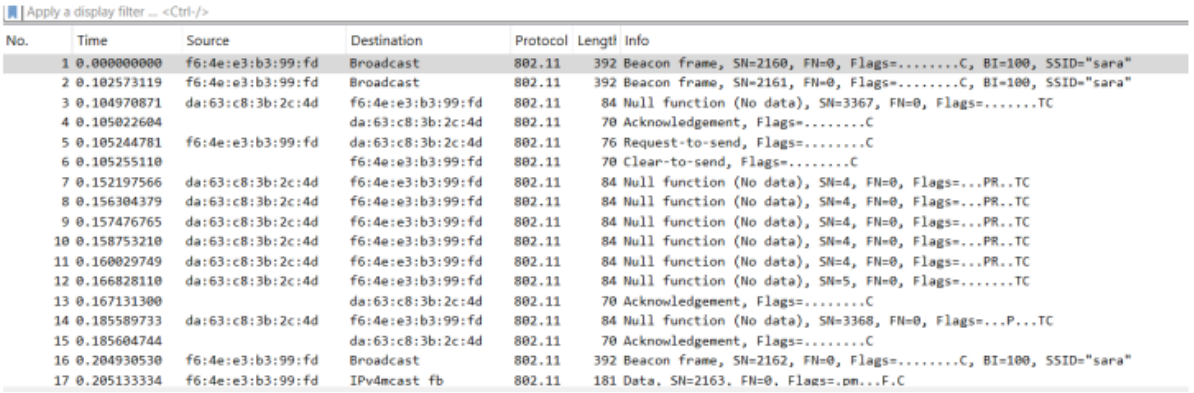


Fig 4 : Wireshark capture

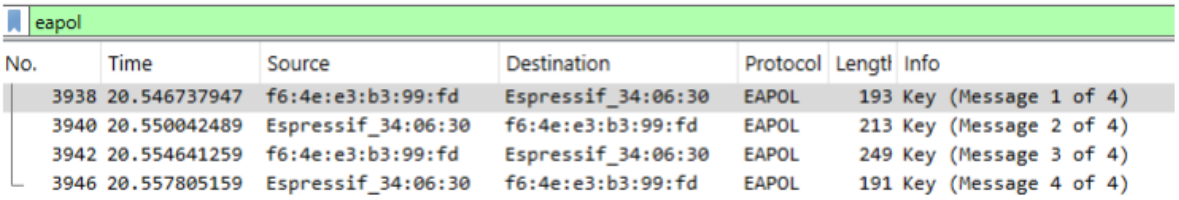


Fig 5: Wireshark EAPOL packets

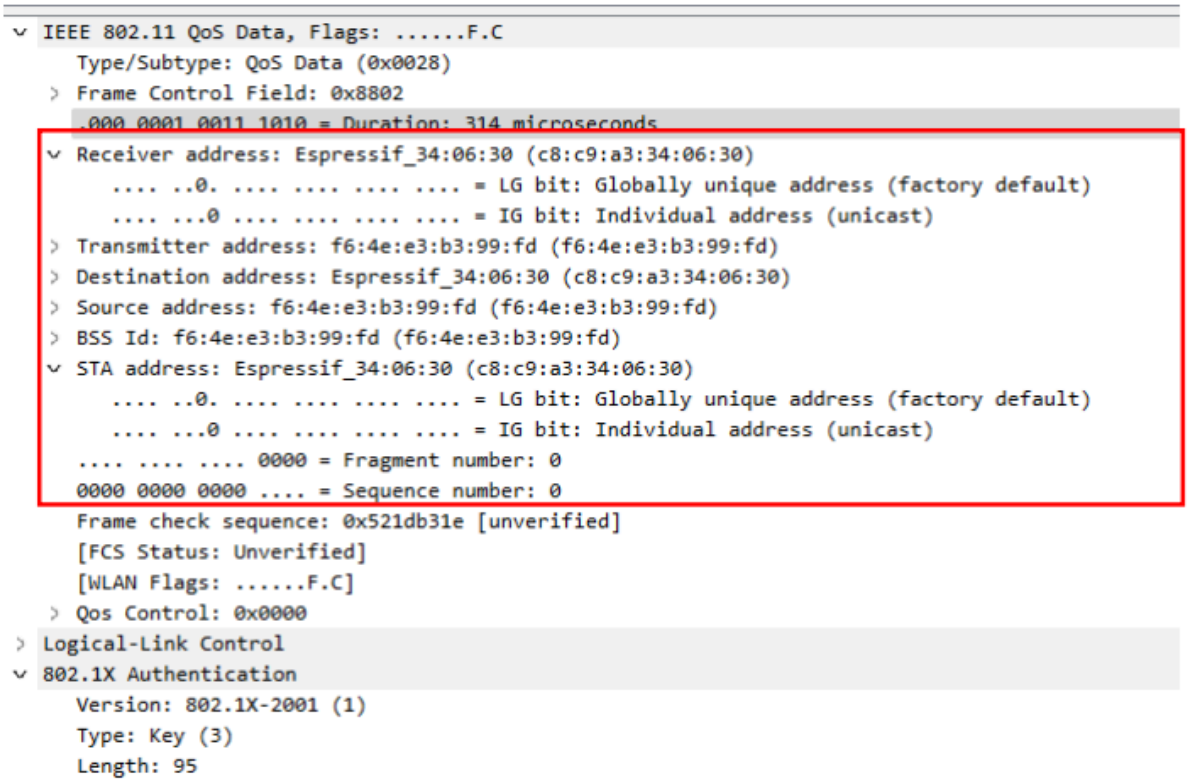


Fig 6 : Details of packets

So here, we simply listened to the traffic of a network by distance. Just by reading the packets, we gained access to information such as the SSID and MAC addresses, it will not be detailed here but just by having theses information, an attacker can make a “spoofing” (Impersonating a device’s identity) attack with this info.

Moreover, we listened to the “handshakes” packets, also called “EAPOL” packets, which contain the encrypted wi-fi credentials. All we needed was Wireshark and an antenna in monitor mode. This "monitor mode" will be explained in the next section.

Wi-Fi monitor mode

The monitor mode of a Wi-Fi antenna allows it to capture all wireless traffic within its range, even if the antenna is not connected to the network. This mode is

crucial for analyzing network vulnerabilities, it enables the collection of raw packets transmitted between devices and access points with Wireshark. This functionality is essential for identifying MAC addresses, SSIDs, and encryption methods, as well as for capturing handshake packets during a re-authentication. It is a fundamental material in network security testing and vulnerability.

To put in monitor mode the antenna, we have write the following commands lines :

```
sudo ip link set [interface] down
sudo iwconfig [interface] mode monitor
sudo ip link set [interface] up
```

If we want to put it back in the first mode, we can write “managed” instead of “monitor”

With this mode, we can listen to the traffic like we did in the previous part, or, we can use this mode to use other tools, like Aircrack.

Aircrack and the deauth attack

Aircrack-ng is a set of tools widely used for analyzing and exploiting Wi-Fi networks. It allows attackers to crack Wi-Fi credentials in the encrypted packets, it can provide key functionalities for testing network vulnerabilities or it can be used by attackers to gain unauthorized access to the network . One of its tools, Aireplay-ng, is particularly effective for launching deauthentication attacks. This technique sends deauthentication packets to connected devices, forcing them to disconnect from the Wi-Fi network. During this process, if the devices try to reconnect, handshake packets are exchanged between the device and the router, which can be captured for further analysis.

Aircrack-ng itself is used to crack Wi-Fi passwords by analyzing these handshake packets. Once the packets are captured, the tool compares the encrypted handshake data against a wordlist to identify the correct password. One of the most commonly used wordlists is “rockyou.txt” which contains millions of frequently used passwords. With this wordlist, Aircrack-ng increases the chances of successfully cracking weak or poorly chosen passwords, allowing unauthorized access to the network. If the correct password exists in the wordlist, the network’s encryption is broken, granting full access to the attacker. This demonstrates the importance of using strong, unique passwords to protect Wi-Fi networks.

In the “Wireshark” part, we managed to capture the “handshake” packets, and we managed to get the MAC address of the network, with a dictionary (a popular

dictionary is “rockyou.txt”), we can “easily” brute force the password if it’s not secured enough.

To make this, we just have to use the Aircrack-command :

```
sudo aircrack-ng -w rockyou.txt -b F6:4E:E3:B3:99:FD -e [network ESSID] [packet]
```

We just wait for the good respond to get the good key :

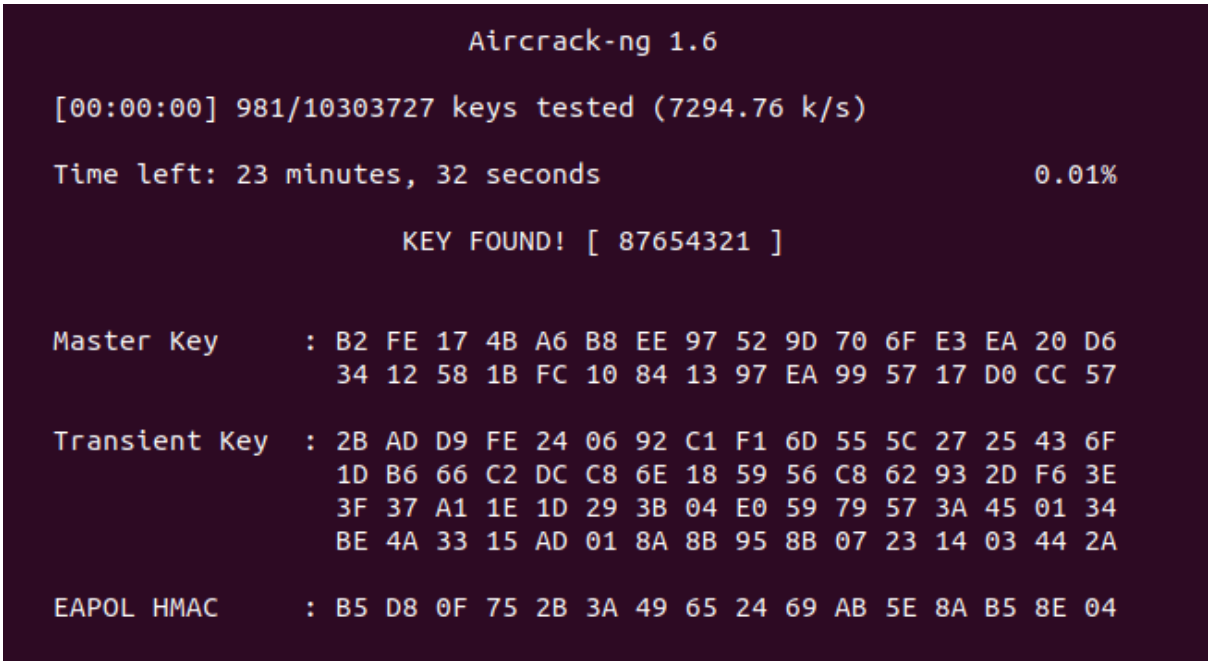


Fig 7 : Key cracked with aircrack

Key found [87654321]: “87654321” is the password of our local network that we used to test this command.

And now the attacker gets the credentials just by listening to the traffic and he can enter the network.

With the same wireshark captures, now that a potential attacker knows the mac address of the differents components of the network, a deauthentication attack is possible because of the WPA protocols, just by knowing the MAC address of the device and the wi-fi router :

```
sudo aireplay-ng -0 1 -a F6:4E:E3:B3:99:FD -c C8:C9:A3:34:06:30 [wlan interface]
```

The first MAC address is the router, the second one is the devices we want to deauthenticate.

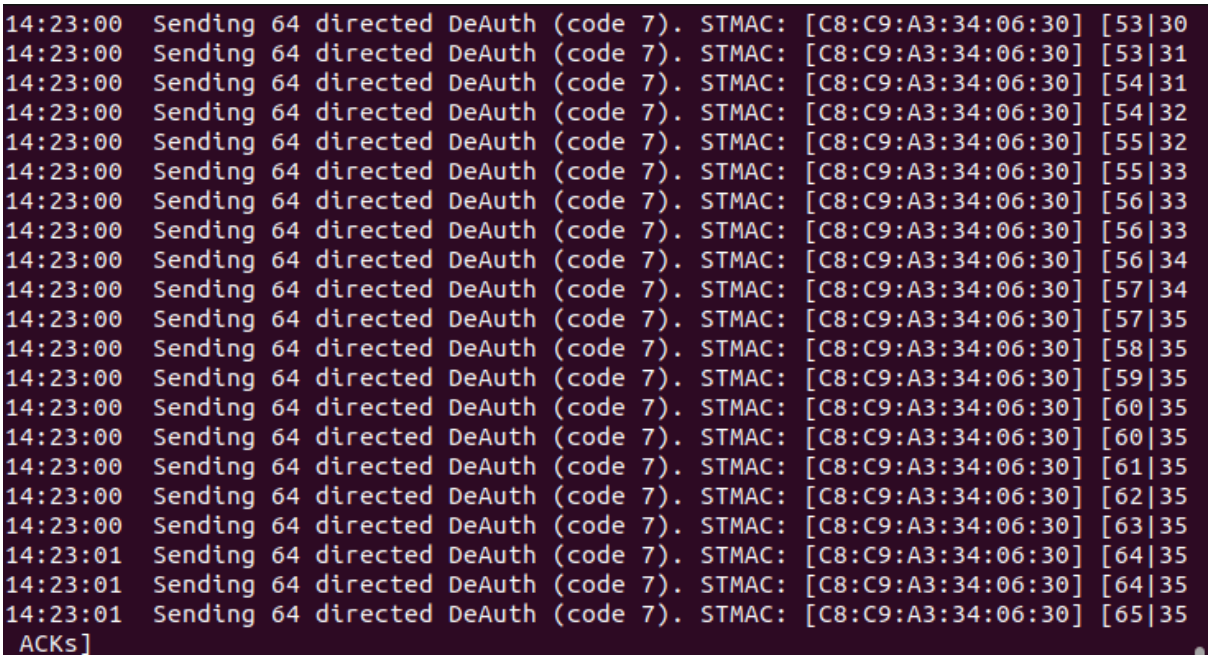


Fig 8 : Sending DeAuth packets

And now the device (here, the smart plug from our project) is disconnected from the network.

If we try to communicate with the smart plug from the phone application, we cannot, but the device will automatically reconnect to the network, so we have to send the command several times in order to keep the smart plug disconnected, or a script with the command, to maintain the sending of packets.

On the app, a message will appear to inform that there are no communication between the smart plug and the phone, or that the signal is not founded, first we thought that the app would not notice the user that the communication is disabled so the user will think that he still can command the device, but in fact, there is a message so if the user try to communicate with the unpair devices he will notice it.

BLE MITM

The BLE Man-in-the-Middle (MITM) attack exploits vulnerabilities in Bluetooth Low Energy (BLE) communication, allowing an attacker to intercept and manipulate data exchanged between a BLE device and its connected application. This attack involves “impersonating” the target device by cloning its characteristics, such as its MAC address and services, and relaying data between the victim device and the application. Tools like Mirage and Whad are commonly used to facilitate this attack. They provide a robust framework for simulating and manipulating BLE devices, enabling attackers to emulate legitimate devices and inject falsified data.However,

the practical implementation of these tools often requires troubleshooting, as compatibility issues, outdated modules, or hardware limitations can lower their performance. Despite these challenges, a successful BLE MITM attack demonstrates the risks posed by unencrypted communications and the lack of robust authentication in many IoT devices.

In these steps, we try to make a Man-In-The middle attack on our sensor “Z_motion”.

See interface and scan

The first step is to detect the BLE device that we want to target by scanning, we can scan by doing the command line :

```
sudo hcitool lescan
```

```
julien@julien-ASUS-TUF-Dash-F15-FX516PM-FX516PM:~/mirage$ sudo hcitool lescan
LE Scan ...
57:31:F1:49:40:D9 (unknown)
57:31:F1:49:40:D9 (unknown)
58:2D:9E:4B:5B:2A (unknown)
58:2D:9E:4B:5B:2A (unknown)
50:C8:A7:3D:3E:DA (unknown)
50:C8:A7:3D:3E:DA (unknown)
57:31:F1:49:40:D9 (unknown)
57:31:F1:49:40:D9 (unknown)
58:2D:9E:4B:5B:2A (unknown)
58:2D:9E:4B:5B:2A (unknown)
57:31:F1:49:40:D9 (unknown)
57:31:F1:49:40:D9 (unknown)
F8:9D:3D:6D:71:AE Z_Motion
F8:9D:3D:6D:71:AE Z_Motion
```

Fig 9 : BLE Scanning

We detected our device “Z_motion” with his MAC address

Now we will try to use the differents tools that we have to try our attack

Mirage

Now we installed Mirage on our Linux PC, but some problems appear. We initially attempted to use Mirage for testing purposes, intending to eventually launch a MITM attack.

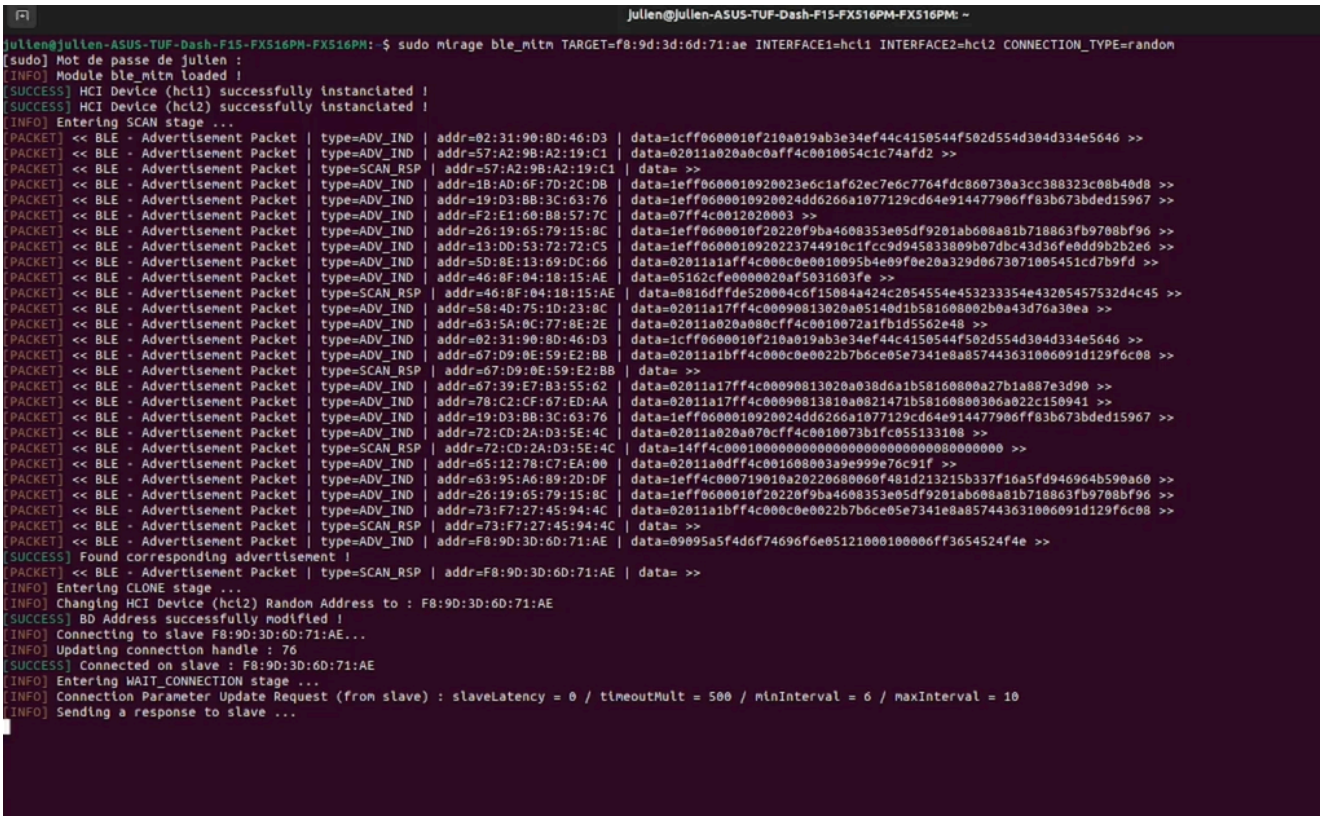


Fig 10 : Mirage interface

We managed to successfully connect to the device with our first BLE dongle and to copy the device with our second BLE dongle , it is not waiting for the smartphone to connect.

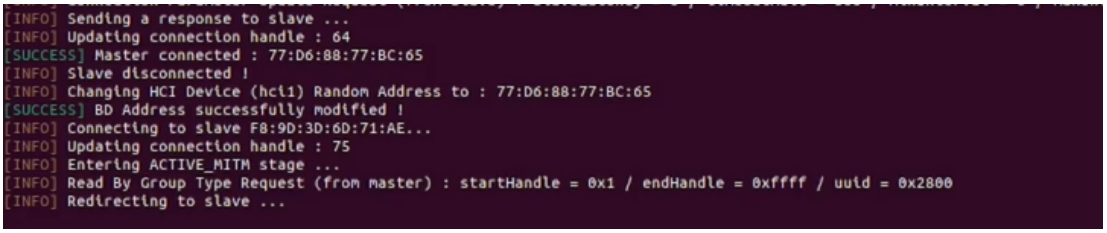


Fig 11 : Smartphone connecting to fake devices

The smartphone is now connected and we see all the information and all the data.



Fig 12 : Recovering of the data

We can now manipulate the data with the “handle” and the “value” in hexadecimal

The man-in-the-middle attack with mirage is a success.

Whad

Another tool in the same subject is “Whad”, created by the same creator of mirage but more recent.

Whad can have an “interactive” function, we can go into that interface and connect to a BLE device :

```
sudo wble-central -i [interface] interactive
```

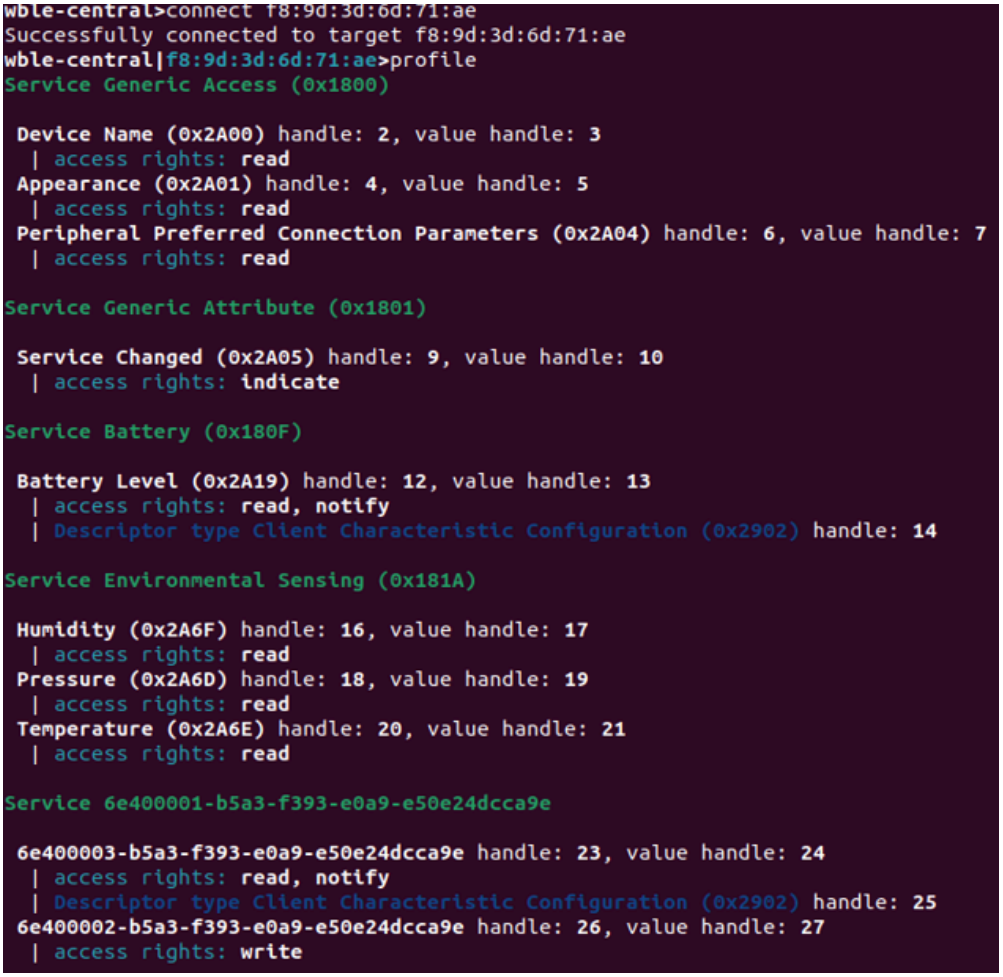


Fig 13 : Whad interactive interface

With this interactive interface, we can connect to a BLE device and have his “profile”.

His “profile” is all the services and characteristics that the device has and this is all the info we need if we want to do a MITM attack because we want to “clone” the device so we need the characteristics.

In addition we can do a BLE scan like “hcitool’ but this gives the same results.

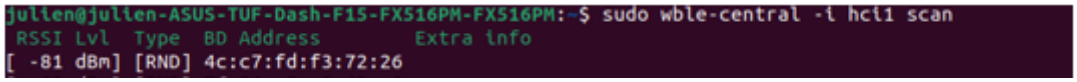


Fig 14 : Whad SCAN

In theory, we should be able to connect to the BLE device and then to copy that information into a JSON file, but after doing the command, again, a problem appears.

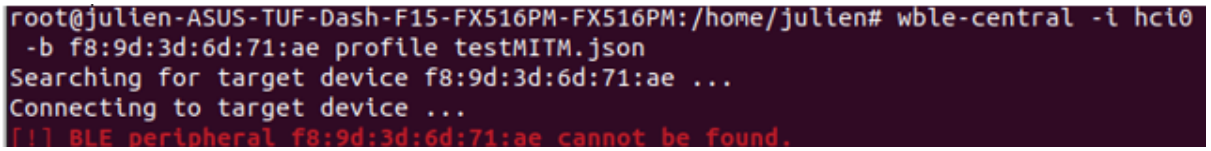


Fig 15 : Whad error

After the command, the BLE device is detected because we gave the good MAC Address, but when we try to connect to the device, we have the error “device not found”, but the step “Connecting to target device” only appear when the sensor is on so it seems to detect the device but somehow the BLE peripheral cannot be connected.

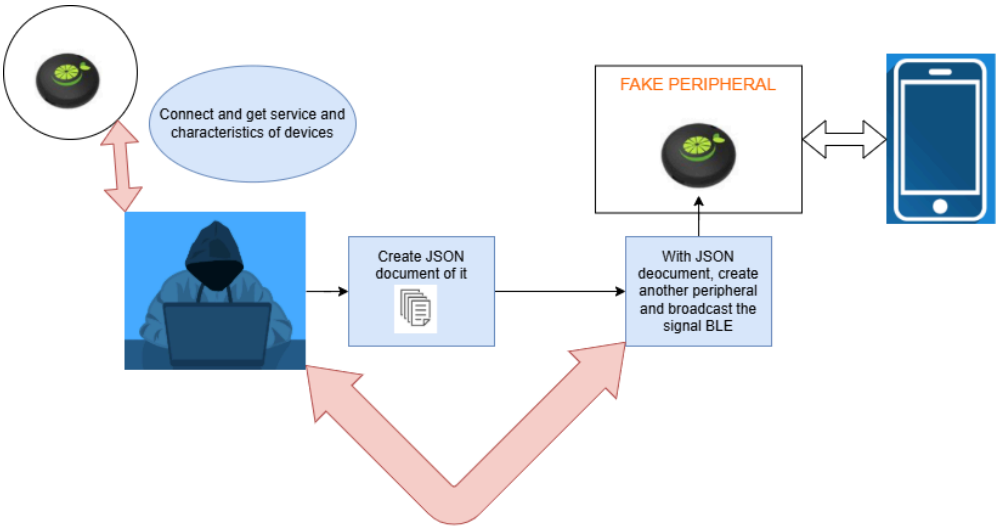


Fig 15 : Theoretical step to MITM with WHAD

Above is the step to do a MITM, the attack begin with a scan then a copy into a JSON document of all the data of the true sensor, in order to replicate them with another BLE dongle to trick the smartphone and to make the user believe that the BLE dongle is the true sensor, but, to date, we can connect to the BLE sensor, we can see his characteristics, but due to unknown circumstances, the command line that was supposed to copy the data into a JSON document is not working. So for now, in practice, we were not able to reproduce the MITM attack with Whad but only with Mirage.